



SIMATS
ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Session Tracking Techniques

B. Sai Manoj Kumar
192411251
B.E - CSE

Introduction

- Session tracking is used to identify and manage user interactions during a web session.
- It helps maintain user information across multiple web pages.
- HTTP is a stateless protocol, so session tracking is required to remember user activities.
- It is widely used in applications such as online shopping, banking, and login systems.
- Session tracking techniques ensure secure, personalized, and continuous user experiences.

HttpSession



Advantages

- Stores complex objects server-side — not limited to strings
- Data never travels over the wire in full — only a session ID is exchanged
- Automatic timeout / invalidation support (`session.invalidate()`)
- Works even when cookies are partially restricted, if paired with URL rewriting



Limitations

- Consumes server memory — scales poorly with concurrent users
- Requires sticky sessions or replication in clustered / load-balanced deployments
- Still depends on a cookie or rewritten URL to carry the session ID
- Session hijacking possible if the session ID is exposed or predictable

Cookies



Advantages

- Persists across browser restarts if given an expiry date (unlike in-memory session)
- Low server overhead — state can live entirely on the client
- Simple, widely supported by every browser and framework
- Can be scoped to a domain/path and shared across requests automatically



Limitations

- Users can disable, block, or manually clear cookies
- Vulnerable to theft via XSS or network sniffing unless Secure/HttpOnly/SameSite flags are set
- Limited storage (~4KB) and count per domain
- Susceptible to cross-site request forgery (CSRF) if not paired with tokens

URL Rewriting



Advantages

- Works when cookies are completely disabled in the browser
- No client-side storage dependency — fully server-driven
- Simple fallback mechanism supported natively by servlet containers
- Useful for stateless clients or bots that don't retain cookies



Limitations

- Session ID is visible in the URL — exposed in browser history, logs, and referrer headers
- Every internal link must be manually rewritten (response.`encodeURL()`)
- Broken or shared links can leak the session, enabling session fixation/hijacking
- Cannot persist across sessions — lost once the URL/tab is discarded

Use-Case Comparison

Choosing the right mechanism depends on persistence, security, and client constraints

Mechanism	Persistence	Security	Best Use Case
HttpSession	Server memory; lasts until timeout/invalidate	Strong — only an ID leaves the server	Storing complex, sensitive user/app state
Cookies	Client-side; can survive browser restarts	Moderate — needs Secure/HttpOnly/ SameSite	"Remember me", preferences, light state
URL Rewriting	None beyond current URL/tab	Weak — ID exposed in URL/logs	Fallback when cookies are disabled

Takeaway: HttpSession offers the strongest security and richest state, but combine it with secure cookies (and URL rewriting as fallback) for a robust, standards-compliant session strategy.

THANK

YOU